เอกสารตรวจสอบระบบ Prompt Hub

17 ตุลาคม 2569 · ผู้พัฒนาระบบ: ครูสมควร สากำ

1. ข้อมูลการตรวจ

ระบบ Prompt Hub ผ่านการตรวจอัตโนมัติครบทุกข้อ (136 + 26 ข้อ) บนเครื่องจริง เมื่อวันที่ 17 ตุลาคม 2569 เอกสารนี้บันทึกผลที่รันจริง และมีแบบตรวจให้กรรมการตรวจซ้ำด้วยตนเอง

รายการ	รายละเอียด
ระบบ	Prompt Hub · เปลี่ยนไอเดียให้เป็นจริงด้วย AI
ผู้พัฒนา	ครูสมควร สากำ
ตำแหน่งติดตั้ง	`C:\xampp\htdocs\prompt_hub` · `http://localhost/prompt_hub/`
สภาพแวดล้อม	Windows 10 Pro · XAMPP Apache 2.4.58 · PHP 8.0.30 · MariaDB 10.4.32
เทคโนโลยี	PHP OOP · MySQLi Prepared Statements · Bootstrap 5.3.3 · utf8mb4
เครื่องมือตรวจ	`tests/integration.py` (ทดสอบ HTTP กับเว็บจริง + ตรวจฐานข้อมูล) · `tests/password_reset.py` (เซิร์ฟเวอร์อีเมลจำลอง) · เบราว์เซอร์ Chromium ที่หน้าจอ 375 px และเดสก์ท็อป

ชุดทดสอบสร้างบัญชีและข้อมูลชั่วคราว ตรวจผลทั้งที่หน้าเว็บและในฐานข้อมูล แล้วลบทิ้งเมื่อจบ รันซ้ำได้ด้วย `python tests\integration.py --allow-test-data`

2. สรุปผลการตรวจ

ผ่านทุกชุดที่รัน ไม่มี PHP warning หรือ error ใน log หลังทดสอบ และข้อมูลทดสอบถูกลบหมด (บัญชี admin/teacher1 และการตั้งค่าเว็บไซต์กลับเป็นค่าเดิม)

ชุดตรวจ	จำนวน	ผล
ทดสอบ HTTP ตามเกณฑ์ตรวจรับ (`integration.py`)	136 ข้อ	ผ่าน 136
ระบบลืมรหัสผ่านกับเซิร์ฟเวอร์อีเมลจำลอง (`password_reset.py`)	26 ข้อ	ผ่าน 26
ตรวจไวยากรณ์ PHP ทุกไฟล์ (PHP 8.0.30)	66+ ไฟล์	ผ่านทุกไฟล์
ป้องกันไฟล์ภายในจากเว็บ (config, database, app, bin, storage, views, tests, docs, .md)	11 เส้นทาง	403 ทุกเส้นทาง

ตรวจในเบราว์เซอร์ (มือถือ 375 px + เดสก์ท็อป)	8 หน้า	ผ่าน ไม่มีหน้าไหนล้นแนวนอน
ติดตั้งบนฐานข้อมูลว่าง และรันซ้ำบนฐานข้อมูลที่มีอยู่	2 กรณี	สำเร็จ / หยุดโดยไม่ทับข้อมูล

ปัญหาที่พบและแก้แล้วระหว่างตรวจ: คำเตือน PHP ในสคริปต์สร้างผู้ดูแล ปุ่มในตารางหลังบ้านตัดบรรทัดบนมือถือ ตัวอักษรไทยใต้โลโก้ซ้อนกัน และตารางในหน้า PDPA แคบเกินไปบนมือถือ

3. ผลตามเกณฑ์ตรวจรับ 13 ข้อ

ผ่านครบ 13 จาก 13 ข้อ ทุกข้อตรวจด้วยการส่งคำขอจริงเข้าเว็บและยืนยันผลในฐานข้อมูล

#	เกณฑ์	วิธีตรวจ	ผล
1	สมัครสมาชิก เข้าสู่ระบบ ออกจากระบบ	สมัคร ⟶ เข้าสู่ระบบ (Session ID เปลี่ยน) ⟶ ออก ⟶ เปิดแดชบอร์ดได้ 401	ผ่าน
2	ป้องกัน username และ email ซ้ำ	สมัครซ้ำได้ 422 พร้อมข้อความ (อีเมลไม่สนตัวพิมพ์) + UNIQUE ในฐานข้อมูล	ผ่าน
3	สมาชิกจัดการได้เฉพาะ Prompt ของตนเอง	สมาชิกอื่นเปิด/แก้/ลบ Prompt ส่วนตัวได้ 404 แก้ Prompt สาธารณะของผู้อื่นได้ 403 ข้อมูลไม่เปลี่ยน	ผ่าน
4	ผู้เยี่ยมชมเข้า Prompt ส่วนตัว/รอตรวจไม่ได้แม้ระบุ URL	เปิดตรงได้ 404 ไม่อยู่ในผลค้นหา ปุ่มคัดลอกและรายการโปรดได้ 404	ผ่าน
5	การอนุมัติและการแก้ไข Prompt ที่เผยแพร่แล้วตามกฎ	ส่งตรวจ ⟶ ไม่อนุมัติพร้อมเหตุผล ⟶ ส่งใหม่ ⟶ อนุมัติ ⟶ สมาชิกแก้ไขแล้วกลับเป็นรอตรวจและหายจากหน้าบ้าน	ผ่าน
6	ค้นหา กรอง เรียง แบ่งหน้าร่วมกัน	คำค้น + หมวด + แท็ก + เครื่องมือ + เรียงพร้อมกัน หน้า 2 มี 4 การ์ด จาก 16 ลิงก์รักษาค่าค้นหา ค่าพารามิเตอร์ผิดรูปใช้ค่าเริ่มต้น	ผ่าน
7	คัดลอก Prompt และแทนค่าตัวแปร	พบตัวแปร 3 ตัว กรอกแล้วข้อความเปลี่ยน ต้นฉบับไม่เปลี่ยน กดคัดลอกแล้วตัวนับเพิ่ม 58 ⟶ 59	ผ่าน
8	เพิ่มรายการโปรดซ้ำไม่ได้	กดเพิ่ม 2 ครั้ง มี 1 แถว (Primary Key)	ผ่าน
9	สมาชิกเข้าหลังบ้านไม่ได้	หน้าหลังบ้าน 8 หน้าได้ 403 คำสั่งหลังบ้านได้ 403 ลดสิทธิ์แล้วเข้าไม่ได้ทันที	ผ่าน
10	คำขอที่ไม่มี CSRF Token ถูกปฏิเสธ	ลบ/แก้โปรไฟล์/คัดลอก/ลืมรหัสผ่าน ไม่มีหรือ token ผิดได้ 403 ใช้ GET ลบได้ 405	ผ่าน
11	HTML/JavaScript ใน Prompt แสดงเป็นข้อความ	`<script>` ถูก escape ใส่ `<img onerror>` ในช่องตัวแปรไม่เกิด element ใหม่ มี CSP ห้าม inline script	ผ่าน

12	ข้อมูลภาษาไทยไม่ผิดเพี้ยน	ชื่อ เนื้อหาหลายบรรทัด แท็ก และอีเมลภาษาไทยอ่านกลับจากฐานข้อมูลตรงทุกไบต์	ผ่าน
13	หน้าหลักใช้งานบนมือถือได้	เบราว์เซอร์ 375 px: ไม่ล้นแนวนอน (scrollWidth = 375) เมนูยุบเป็นปุ่ม การ์ดสถิติ 2×2	ผ่าน

4. ความปลอดภัย

ทุกข้อกำหนดด้านความปลอดภัย 16 ข้อมีอยู่ในโค้ด โดย 15 ข้อตรวจด้วยการทดสอบจริง และ 1 ข้อ (ไม่มีการอัปโหลดไฟล์) ตรวจจากโค้ด

ข้อกำหนด	ที่ทำไว้ในระบบ	ตรวจด้วย
เก็บรหัสผ่านปลอดภัย	`password_hash()` / `password_verify()` (bcrypt `$2y$`)	ทดสอบ + ฐานข้อมูล
กัน SQL Injection	MySQLi Prepared Statements ทุกคำสั่ง ไม่ใช้ PDO	ทดสอบ (`id;DROP TABLE users`) + โค้ด
การเรียงลำดับใช้รายการที่อนุญาต	ค่าที่ไม่อยู่ในรายการใช้ค่าเริ่มต้น	ทดสอบ
กัน XSS	escape ทุกจุด เนื้อหาแสดงเป็นข้อความ + Content-Security-Policy	ทดสอบ + เบราว์เซอร์
กัน CSRF	Token ทุก POST ไม่มีการเปลี่ยนข้อมูลผ่าน GET	ทดสอบ
ตรวจสิทธิ์ฝั่งเซิร์ฟเวอร์	ตรวจการเข้าสู่ระบบ บทบาท สถานะบัญชี ความเป็นเจ้าของ ทุกคำขอ	ทดสอบ
Session ปลอดภัย	เปลี่ยน Session ID หลังเข้าระบบ, cookie HttpOnly + SameSite=Lax, หมดอายุ 2 ชม.	ทดสอบ (การหมดอายุยังไม่ได้ทดสอบ)
จำกัดการเข้าระบบผิด	5 ครั้ง/บัญชี+IP, 20 ครั้ง/IP ใน 15 นาที	ทดสอบ (ครั้งที่ 6 ได้ 429)
บัญชีที่ถูกระงับ	หลุดออกทันทีและเข้าไม่ได้	ทดสอบ
เปลี่ยนรหัสผ่านต้องยืนยันรหัสเดิม	และ session อื่นหมดสิทธิ์	ทดสอบ
ตรวจชนิด ความยาว ค่าที่รับ	คลาส Validator ทุกฟอร์ม	ทดสอบ
แยกค่าเชื่อมต่อออกจากเว็บ	`config/` อยู่นอก `public/` และถูกปฏิเสธ 403	ทดสอบ
ไม่แสดงรายละเอียดภายในต่อผู้ใช้	บันทึกลง `storage/logs` ไม่เก็บค่าพารามิเตอร์ (รหัสผ่าน) ใน log	ทดสอบ (รหัส SMTP ไม่อยู่ใน log)

ผู้ดูแลคนสุดท้าย	ระงับ/ลบ/ลดสิทธิ์ตัวเองไม่ได้ ล็อกแถวด้วย `FOR UPDATE`	ทดสอบ (ยังไม่ทดสอบการกดพร้อมกัน)
ไม่มีบัญชีเริ่มต้นฝังในโค้ด	ผู้ติดตั้งตั้งรหัสผ่านผู้ดูแลเองผ่าน CLI	ทดสอบ (ปฏิเสธรหัสสั้น) + โค้ด
ไม่มีการอัปโหลดไฟล์	ไม่มีฟอร์มอัปโหลดในรุ่นนี้	โค้ด

5. PDPA และระบบลืมรหัสผ่าน

ผ่านทุกข้อที่ตรวจ ยกเว้นการส่งอีเมลผ่าน Gmail จริงที่ยังไม่ได้ตรวจ (ตรวจกับเซิร์ฟเวอร์อีเมลจำลองแทน)

รายการ	ผลที่ตรวจพบ	ผล
หน้านโยบายความเป็นส่วนตัว	เปิดได้จากส่วนท้ายทุกหน้า มี 8 หัวข้อ รวมรายละเอียดคุกกี้	ผ่าน
ยอมรับนโยบายก่อนสมัคร	ไม่ติ๊กได้ 422 และไม่สร้างบัญชี ติ๊กแล้วบันทึกเวลาที่ยอมรับ	ผ่าน
แถบแจ้งคุกกี้	แสดงเมื่อยังไม่กดรับทราบ ซ่อนหลังกด	ผ่าน
ตั้งค่าผู้ควบคุมข้อมูลและช่องทางติดต่อ	แก้ในหลังบ้านแล้วแสดงในหน้านโยบาย	ผ่าน
ลิงก์ตั้งรหัสผ่านใช้ได้ครั้งเดียว หมดอายุ 60 นาที	ใช้ซ้ำได้ 410 ลิงก์หมดอายุได้ 410 ขอใหม่แล้วลิงก์เก่าใช้ไม่ได้	ผ่าน
ไม่เปิดเผยว่าอีเมลมีบัญชีหรือไม่	อีเมลที่ไม่มีบัญชีได้ข้อความเดียวกัน	ผ่าน
เก็บเฉพาะ hash ของลิงก์	ฐานข้อมูลมี SHA-256 ไม่มี token จริง	ผ่าน
ลิงก์ไม่ถูกปลอมจาก Host header	ส่ง Host ปลอม ลิงก์ยังใช้ `app_url`	ผ่าน
จำกัดคำขอ	ครั้งที่ 4 ต่ออีเมลใน 1 ชั่วโมงได้ 429	ผ่าน
ส่งอีเมลไม่สำเร็จ	ผู้ใช้เห็นข้อความเดิม ไม่เหลือ token และ log ไม่มีรหัส SMTP	ผ่าน
ส่งผ่าน Gmail จริง (TLS)	ยังไม่ได้กรอกค่า SMTP จริง	ยังไม่ได้ตรวจ

6. แบบตรวจด้วยตนเองสำหรับกรรมการ

กรรมการทำตาม 14 ขั้นตอนนี้บนเว็บจริง ใช้เวลาประมาณ 30 นาที เลือกผลในช่อง “ผล” และพิมพ์หมายเหตุได้ในตาราง ใช้บัญชีทดสอบที่สร้างใหม่ ไม่ใช้บัญชีจริงของครู

#	ขั้นตอนตรวจ	ผลที่ควรได้	ผล	หมายเหตุ
1	เปิดหน้าแรกบนมือถือ	เห็นชื่อ สโลแกน ช่องค้นหา ไม่ต้องเลื่อนซ้ายขวา		
2	ค้นหาคำว่า “แผนการสอน”	พบ Prompt ที่เกี่ยวข้อง		

3	กรองหมวดหมู่ + เรียง “คัดลอกมากที่สุด” แล้วเปลี่ยนหน้า	ตัวกรองและการเรียงยังอยู่		
4	เปิด Prompt ที่มี [ตัวแปร] กรอกค่า แล้วกดคัดลอก	ข้อความเปลี่ยนตามค่า วางในโปรแกรมอื่นได้ ตัวนับเพิ่ม 1		
5	สมัครสมาชิกโดยไม่ติ๊กยอมรับ PDPA แล้วติ๊ก	ครั้งแรกถูกปฏิเสธ ครั้งที่สองสมัครได้		
6	สมัครซ้ำด้วยชื่อผู้ใช้เดิม	ขึ้น “ชื่อผู้ใช้นี้ถูกใช้แล้ว”		
7	สร้าง Prompt ส่วนตัว คัดลอก URL ไปเปิดในหน้าต่างที่ไม่ได้เข้าสู่ระบบ	ขึ้น “ไม่พบ Prompt” (404)		
8	ใส่ `<script>alert(1)</script>` ในเนื้อหา Prompt แล้วเปิดดู	เห็นเป็นข้อความ ไม่มีกล่องเด้ง		
9	ส่งตรวจ แล้วผู้ดูแลไม่อนุมัติพร้อมเหตุผล	สมาชิกเห็นเหตุผลในหน้า Prompt ของฉัน		
10	แก้แล้วส่งใหม่ ผู้ดูแลอนุมัติ	Prompt ปรากฏหน้าบ้านและผลค้นหา		
11	สมาชิกเปิด `index.php?r=admin`	ขึ้น “หน้านี้สำหรับผู้ดูแลระบบเท่านั้น” (403)		
12	กดเพิ่มรายการโปรด 2 ครั้ง	หน้ารายการโปรดมีรายการเดียว		
13	เปิด `/prompt_hub/config/config.php` ในเบราว์เซอร์	ขึ้น 403 Forbidden		
14	ลืมรหัสผ่าน (หลังตั้งค่า SMTP)	ได้อีเมลภายในไม่กี่นาที ตั้งรหัสใหม่แล้วเข้าระบบได้		

7. ข้อจำกัดและส่วนที่ยังไม่ได้ทดสอบ

รายการต่อไปนี้ยังไม่ได้ตรวจ จึงยังรับรองไม่ได้ว่าทำงานถูกต้อง

- **PHP 8.2 ขึ้นไป** — เครื่องทดสอบมี PHP 8.0.30 (ต่ำกว่าที่ข้อกำหนดระบุ) โค้ดไม่ใช้คำสั่งที่เลิกใช้ใน 8.2 แต่ยังไม่ได้รันจริง
- **MySQL 8 แท้** — ทดสอบบน MariaDB 10.4
- **ส่งอีเมลผ่าน Gmail จริงและการเข้ารหัส TLS** — ตรวจกับเซิร์ฟเวอร์จำลองที่ไม่เข้ารหัสเท่านั้น (แบบตรวจข้อ 14)
- **การพิมพ์รหัสผ่านแบบซ่อนตัวอักษรในสคริปต์ติดตั้ง** — ทดสอบเฉพาะการส่งข้อมูลเข้าสคริปต์ตรง ๆ
- **เนื้อหาใน clipboard** — ปุ่มคัดลอกรายงานสำเร็จ แต่ไม่ได้อ่านค่ากลับมายืนยัน
- **เบราว์เซอร์อื่น** — ตรวจเฉพาะ Chromium ยังไม่ได้ตรวจ Safari, Firefox และมือถือจริง
- **HTTPS และ session หมดอายุ 2 ชั่วโมง** — ยังไม่ได้ทดสอบ

- **ผู้ใช้จำนวนมากพร้อมกัน และข้อมูลหลายหมื่นรายการ** — ยังไม่ได้ทดสอบความเร็ว
- **ความถูกต้องทางกฎหมายของหน้า PDPA** — ต้องให้หน่วยงานหรือ DPO ตรวจทาน

สิ่งที่ระบบยังไม่มี: หน้าแก้อีเมล ปุ่มดาวน์โหลดข้อมูลของตนเอง และปุ่มลบบัญชีตนเอง และหน้าเว็บต้องใช้อินเทอร์เน็ตเพื่อโหลด Bootstrap และฟอนต์

8. การรับรองผลการตรวจ

ความเห็นกรรมการ:

☐ ผ่าน พร้อมใช้งาน

☐ ผ่าน โดยมีเงื่อนไข (ระบุในหมายเหตุ)

☐ ไม่ผ่าน ให้แก้ไขแล้วตรวจใหม่

หมายเหตุ: .....

บทบาท	ชื่อ-สกุล	ลงนาม	วันที่
ผู้พัฒนาระบบ	ครูสมควร สากำ		
กรรมการตรวจ			
กรรมการตรวจ			
ประธานกรรมการ			